Zero Trust Access Broker: What Each Zone Does

Graduation project · 14 October 2026

The broker checks every login, web request and SSH connection against identity, device health and risk, and can cut access mid-session. The architecture follows NIST SP 800-207 and is split into five zones.

1. Employee side

Everything the employee touches. These parts prove who the person is and what state their device is in.

Component	What it does	Arrow out	Track
Hardware passkey	Our own FIDO2 key. The fingerprint is matched on the key, and the secure chip signs the login challenge. The private key never leaves the chip and the fingerprint never reaches the server.	"signs login" to the login portal	**Hardware**
Login portal	The web page where employees sign in with the passkey and request temporary access ("X for 30 minutes").	"sign in" to the web proxy	**Client Apps**
SecureVault app	The original proposal, now one module. Stores and shares team credentials and handles recovery. Requests short-lived SSH certificates instead of keeping permanent keys.	"request cert" to the SSH CA	**Client Apps**
k-of-n recovery shares	The vault secret is split with Shamir's Secret Sharing, for example into 5 shares held by teammates, the admin and a paper backup. Any 3 rebuild it; 2 reveal nothing.	"rebuild" into SecureVault	**Security**
SSH helper (CLI)	The employee types ssh myserver as usual. The helper sends the SPA knock packet and gets a certificate from the CA first.	to the SSH CA and to Single Packet Auth	**Client Apps**
Device posture agent	Runs silently with no UI. Reports OS version, disk encryption status and root or jailbreak state.	"device health" to risk scoring	**Client Apps**

Why it matters: identity is tied to a physical key and a finger, not a password or an IP address. Aher (2025) shows that identifying users by IP fails on shared networks.

2. Enforcement points

The gates. In NIST terms these are Policy Enforcement Points: they never decide on their own, they ask the Policy Engine and enforce the answer.

Component	What it does	Arrows	Track
Web reverse proxy (PEP)	Sits in front of every internal web app. On every request, not just the first, it asks the Policy Engine whether to let the request through.	"ask" to the Policy Engine; "allowed traffic" to internal web apps	**Networking**
SSH Certificate Authority	Replaces static SSH keys. Before signing, it asks the Policy Engine. If allowed, it signs a certificate valid for one server for about 30 minutes. Servers trust only the CA.	"ask" to the Policy Engine; "30-min cert" to Linux servers	**Security**
Single Packet Auth (stretch)	Keeps the servers' SSH port fully closed, so scanners see nothing. The SSH helper sends one signed packet; if valid, SPA opens the port for that IP for a few seconds.	from the SSH helper; opens the port on the Linux servers	**Networking**

Why it matters: a stolen certificate expires on its own, a stolen laptop holds no permanent keys, and with SPA an attacker cannot even reach the port.

3. Decision brain

Where every decision is made, carried out and recorded. NIST SP 800-207 names these parts but leaves the trust algorithm undefined; defining it is part of our contribution.

Component	What it does	Arrows	Track
Policy Engine	Makes every decision: allow, deny or needs approval. Inputs are passkey identity, device health, the risk score and the admin's policies.	receives "ask" from both PEPs; consults risk scoring	**Backend**
Risk scoring + ML	Gives each request a trust score. Rules start at 100 and deduct for signals such as a new device, impossible travel or odd hours. An ML anomaly model adds what rules miss, such as 15x normal downloads.	receives "device health"; sends "score"	**AI / ML**
Policy Administrator	Carries out decisions. Opens sessions and kills them the moment the score drops below the threshold.	"open / kill session" to the proxy; "log" to the audit chain	**Backend**
Audit chain	Records every decision. Each entry holds the hash of the previous one, so any edit or deletion breaks the chain and is detected.	"timings" to the latency dashboard	**Security**

Why it matters: decisions are continuous, not one-time at login. Dhiman et al. (2024) list continuous trust evaluation as an open problem.

4. Protected resources

What the system protects. Nothing here is reachable directly; every path goes through an enforcement point.

Component	What it does	Arrow in	Track
Internal web apps	Demo targets such as Grafana, HR and a wiki. Reachable only through the web proxy.	"allowed traffic" from the proxy	**Security (DevOps)**
Linux servers	Trust certificates signed by our CA only. No authorized_keys files full of old employee keys.	"30-min cert" from the SSH CA	**Security (DevOps)**

5. Admin side

Where admins control the system and where we prove it works.

Component	What it does	Arrow	Track
Admin dashboard	Write policies, enroll devices, approve just-in-time requests, watch live sessions and kill any session in one click.	"policies, approvals, kill" to the Policy Administrator	**Client Apps**
Latency dashboard	Shows live how many milliseconds each security check adds per request.	"timings" from the audit chain	**Security (DevOps)**
Attack demo panel	Triggers attacks live, such as replaying a stolen certificate or connecting from a compromised device, so the committee watches them get blocked.	"simulated attacks" to the proxy	**Security (Testing)**

Why it matters: Fernandez & Brazhuk (2024) note that no working Zero Trust system publishes its overhead figures. The latency dashboard closes that gap directly.

6. How the zones work together

Three stories to trace on the diagram, each crossing every zone.

Web login

1. The passkey signs the login and the employee signs in at the login portal.
2. The web proxy asks the Policy Engine.
3. The engine checks the risk score and device health, then allows.
4. Traffic reaches the internal web app.
5. The decision is written to the audit chain.

SSH to a server

1. The employee types ssh server.
2. The SSH helper sends the SPA knock and requests a certificate.
3. The SSH CA asks the Policy Engine; production may need admin approval from the dashboard.
4. The CA signs a 30-minute certificate and the employee connects.
5. The certificate expires on its own. Replaying it in the attack demo fails.

Attack mid-session

1. The posture agent reports disk encryption was turned off, and the ML flags unusual downloads.
2. The risk score drops below the threshold.
3. The Policy Administrator kills the session at the proxy.
4. The employee is notified and the admin gets an alert.
5. Every step is recorded in the audit chain.